Veri İşleme Sözleşmesi (KVKK / GDPR)

QRNot Dijital Ürün Pasaportu (DPP) hizmeti için

> **TASLAK — HUKUKİ İNCELEME GEREKİR.** Bu metin bir şablondur. İmzalanmadan önce bir avukat tarafından incelenmeli, köşeli parantez içindeki [ ] alanlar doldurulmalıdır. Verilerin ABD'de işlenmesi nedeniyle KVKK m.9 kapsamındaki standart sözleşmenin Kişisel Verileri Koruma Kurulu'nun yayımladığı güncel metinle birebir kullanılması ve imzadan sonra süresi içinde Kurum'a bildirilmesi gerekir.

---

1. Taraflar

Veri Sorumlusu ("Müşteri"): [Firma unvanı], [adres], [vergi dairesi / no], [MERSİS no]

Veri İşleyen ("QRNot"): SCE INNOVATION LTD. ŞTİ., Çetin Emeç Bulvarı 25/3, Çankaya / Ankara, [vergi dairesi / no], [MERSİS no]

Bu sözleşme, taraflar arasındaki [tarih] tarihli QRNot DPP hizmet sözleşmesinin ("Ana Sözleşme") ekidir. Çelişki halinde kişisel verilerin korunmasına ilişkin konularda bu sözleşme uygulanır.

2. Tanımlar

Bu sözleşmede geçen "kişisel veri", "işleme", "veri sorumlusu", "veri işleyen", "ilgili kişi" ve "açık rıza" kavramları 6698 sayılı Kişisel Verilerin Korunması Kanunu ("KVKK") ve uygulandığı ölçüde (AB) 2016/679 sayılı Genel Veri Koruma Tüzüğü ("GDPR") ile aynı anlamı taşır.

3. İşlemenin konusu, süresi ve amacı

1. QRNot, Müşteri adına ve yalnızca Ana Sözleşme kapsamındaki DPP hizmetini sunmak amacıyla kişisel veri işler.
2. İşlemenin niteliği: barındırma, depolama, görüntüleme, kullanıcı kimlik doğrulama, istatistik üretme ve (Müşteri talep ettiğinde) otomatik çeviri.
3. Süre: Ana Sözleşme süresince ve 9. maddede belirtilen iade/silme süreci tamamlanana kadar.
4. İşlenen veri kategorileri ve ilgili kişi grupları **Ek-1**'de belirtilmiştir.

4. Müşterinin yükümlülükleri

1. Müşteri, QRNot'a aktardığı kişisel verilerin hukuka uygun olarak elde edildiğinden, gerekli aydınlatmanın yapıldığından ve gerektiğinde açık rızanın alındığından sorumludur.
2. Müşteri, pasaportun herkese açık bölümlerine kişisel veri girmemeye özen gösterir. Herkese açık bölümlerde yayımlanan bilgilerden Müşteri sorumludur.
3. Müşteri, yetkili erişim anahtarını ve tedarikçi linklerini yalnızca yetkili kişilerle paylaşır.

TASLAK

5. QRNot'un yükümlülükleri

1. **Talimata uygunluk:** QRNot kişisel verileri yalnızca Müşterinin belgelenmiş talimatlarıyla (Ana Sözleşme, bu sözleşme ve panelde yapılan işlemler dahil) işler. Bir talimatın mevzuata aykırı olduğunu düşünürse Müşteriyi gecikmeksizin bilgilendirir.
2. **Gizlilik:** Kişisel verilere erişen QRNot çalışanları ve yüklenicileri gizlilik yükümlülüğü altındadır.
3. **Güvenlik:** QRNot, **Ek-2**'de belirtilen teknik ve idari tedbirleri uygular. Tedbirler, güvenlik seviyesini düşürmemek kaydıyla teknik gelişmelere göre güncellenebilir.
4. **İlgili kişi talepleri:** QRNot, ilgili kişilerin KVKK m.11 / GDPR m.15–22 kapsamındaki taleplerinin yanıtlanmasında Müşteriye makul ölçüde yardım eder. QRNot'a doğrudan gelen talepleri Müşteriye iletir.
5. **Veri ihlali:** QRNot, Müşteri verilerini etkileyen bir kişisel veri ihlalini öğrendiğinde Müşteriyi gecikmeksizin ve en geç [48] saat içinde bilgilendirir; ihlalin niteliği, etkilenen veri kategorileri, olası sonuçları ve alınan önlemler hakkında bilgi verir. Kurul ve ilgili kişilere bildirim yükümlülüğü veri sorumlusu olarak Müşteriye aittir; QRNot bu süreçte yardımcı olur.
6. **Kayıt:** QRNot, Müşteri adına yürütülen işleme faaliyetlerine ilişkin gerekli kayıtları tutar.

6. Alt işleyenler

1. Müşteri, **Ek-3**'te listelenen alt işleyenlerin kullanılmasına genel izin verir.
2. QRNot, yeni bir alt işleyen eklemeden veya mevcut birini değiştirmeden en az [30] gün önce Müşteriyi yazılı olarak (e-posta dahil) bilgilendirir. Müşteri bu süre içinde haklı gerekçeyle itiraz edebilir; itirazın giderilememesi halinde Müşteri ilgili hizmeti cezasız olarak sonlandırabilir.
3. QRNot, alt işleyenlere bu sözleşmedekilerle esasen aynı veri koruma yükümlülüklerini yükler ve alt işleyenlerin eylemlerinden Müşteriye karşı sorumludur.

7. Yurt dışına aktarım

1. Taraflar, hizmetin altyapısının ABD'de bulunduğunu (Ek-3) ve bu nedenle kişisel verilerin yurt dışına aktarıldığını kabul eder.
2. **KVKK:** Aktarım, KVKK m.9 uyarınca uygun güvencelerden biri olan **standart sözleşme** ile yapılır. Taraflar, Kişisel Verileri Koruma Kurulu'nun yayımladığı standart sözleşmeyi (veri sorumlusundan veri işleyene modülü) ayrıca imzalar; standart sözleşme imzalandıktan sonra mevzuatta öngörülen süre içinde Kurum'a bildirilir.
3. **GDPR:** Müşteri AB'de yerleşikse veya GDPR'a tabiyse, aktarım Avrupa Komisyonu'nun 2021/914 sayılı kararıyla kabul edilen **Standart Sözleşme Maddeleri (SCC)** — Modül 2 (veri sorumlusundan veri işleyene) — ile yapılır ve SCC bu sözleşmenin ayrılmaz parçası olarak eklenir.
4. **AB bölgesi seçeneği:** Müşterinin talebi ve ayrıca kararlaştırılacak koşullarla veritabanı ve dosyalar AB bölgesine (ör. Frankfurt) taşınabilir. Bu durumda Ek-3 güncellenir.

8. Denetim

1. QRNot, bu sözleşmeye uyumu göstermek için gerekli bilgileri Müşteriye sağlar ve Müşterinin güvenlik soru formlarını makul sürede yanıtlar.
2. Müşteri, yılda en fazla bir kez, en az [30] gün önceden yazılı bildirimle, masrafları kendisine ait olmak üzere ve gizlilik yükümlülüğü altındaki bir denetçi aracılığıyla denetim yapabilir. Altyapı sağlayıcılarının tesislerinin denetimi, bu sağlayıcıların yayımladığı bağımsız denetim raporları ve sertifikalarla karşılanır.

TASLAK

9. Sözleşmenin sona ermesi: iade ve silme

1. Ana Sözleşme sona erdiğinde QRNot, Müşterinin talebi üzerine ürün verilerini, belgeleri ve seri numaralarını makine okunur biçimde (JSON / CSV ve dosyalar) teslim eder.
2. Yayınlanmış pasaportlar, ürünlerin piyasada bulunduğu süre boyunca erişilebilir kalması gerekebileceğinden, taraflar şu seçeneklerden birini yazılı olarak belirler: (a) yayınlanmış pasaportların [X] yıl daha ayrı bir ücret karşılığı yayında tutulması, (b) Müşterinin kendi altyapısına taşıma için yönlendirme süresi, (c) silme.
3. Belirlenen süre sonunda kişisel veriler, mevzuat gereği saklanması zorunlu olanlar hariç, [90] gün içinde silinir veya anonim hale getirilir ve Müşteriye yazılı olarak teyit edilir. Yedeklerdeki kopyalar, yedekleme döngüsü içinde silinir.

10. Sorumluluk ve diğer hükümler

1. Tarafların bu sözleşmeden doğan sorumluluğu Ana Sözleşmedeki sorumluluk hükümlerine tabidir; ancak [kasıt ve ağır ihmal halleri saklıdır].
2. Bu sözleşmeye Türk hukuku uygulanır; uyuşmazlıklarda [İstanbul] mahkemeleri ve icra daireleri yetkilidir. GDPR SCC eklendiği ölçüde, SCC'nin uygulanacak hukuk ve yetki hükümleri saklıdır.

Ek-1 — İşleme ayrıntıları

Konu	Açıklama
İlgili kişi grupları	Müşterinin panel kullanıcıları (çalışanlar); Müşterinin tedarikçilerinin yetkilileri; Müşterinin pasaportlarda adını yazdığı kişiler (ör. üretici / ithalatçı irtibat kişisi)
Kişisel veri kategorileri	Kimlik (ad soyad), iletişim (e-posta, telefon — girildiyse), kullanıcı işlem bilgisi (rol, son giriş zamanı, yayınlayan kullanıcının e-postası), tedarikçi yanıtındaki ad / e-posta ve tedarikçinin yüklediği belgelerde yer alabilecek kişisel veriler
Pasaport okutmaları	Okutan kişinin IP adresi **saklanmaz**. Sadece ülke kodu, dil ve zaman istatistik için tutulur; bu bilgiler tek başına bir kişiyi belirlemez.
Özel nitelikli veri	İşlenmesi amaçlanmaz. Müşteri, panele özel nitelikli kişisel veri girmez.
İşleme amacı	DPP hizmetinin sunulması: hesap yönetimi, yetkilendirme, pasaport yayınlama, belge saklama, tedarikçi bilgi toplama, çeviri, istatistik
Saklama süresi	Ana Sözleşme süresi + madde 9'daki süreç

Ek-2 — Teknik ve idari tedbirler

Alan	Tedbir
Aktarım şifrelemesi	Tüm trafik HTTPS (TLS); HSTS etkin
Depolama şifrelemesi	Veritabanı sağlayıcısı (Neon) depolanan veriyi AES-256 ile şifrelediğini belirtmektedir
Şifreler	Tuzlanmış scrypt özeti; düz metin saklanmaz

Alan	Tedbir
Oturumlar	Rastgele oturum anahtarı, veritabanında yalnızca SHA-256 özeti; httpOnly + secure çerez; 14 gün geçerlilik
Giriş koruması	Art arda hatalı girişte geçici kilit; panel ve yükleme işlemlerinde istek sınırı
Yetkilendirme	Firma bazında veri ayrımı (her sorgu oturumdaki firmayla sınırlı); yönetici / editör / izleyici rolleri
Hassas pasaport alanları	Sadece yenilenebilir "yetkili erişim anahtarı" ile görünür
Dosyalar	Özel (private) depolama; her erişim sunucu tarafında yetki kontrolünden geçer
Tedarikçi linkleri	192 bit rastgele, süreli link; tedarikçi sadece kendi talebine erişir; veriler firma onayı olmadan ürüne aktarılmaz
Veri minimizasyonu	Okutmalarda IP saklanmaz; otomatik çeviride sadece ürün metinleri gönderilir
Değişmezlik	Yayınlanan her pasaport değiştirilemez bir sürüm olarak saklanır
Sertifikalar	QRNot'un kendisinin ISO 27001 / SOC 2 sertifikası **yoktur**. Altyapı sağlayıcılarının sertifikaları kendi sitelerinde yayımlanır.

Ek-3 — Alt işleyenler

Alt işleyen	Hizmet	Konum
Vercel Inc.	Uygulama barındırma, dosya depolama (Vercel Blob)	ABD
Neon Inc. (Amazon Web Services altyapısında)	PostgreSQL veritabanı	ABD — AWS us-east-1
Anthropic PBC	Otomatik çeviri (sadece Müşteri çeviri istediğinde; ürün metinleri)	ABD

Veri Sorumlusu (Müşteri) — Ad Soyad / Unvan / İmza / Tarih

Veri İşleyen (QRNot) — Ad Soyad / Unvan / İmza / Tarih

TASLAK